

ARCHITECTURE DIAGRAM

IPB Food Hub & UMKM

Platform Marketplace Digital UMKM Kampus Berbasis Web

Mata Kuliah: Keamanan Informasi (KOM1315)

Program: Ilmu Komputer, FMIPA IPB University

Semester: Genap 2025/2026

Daftar Isi

1. Overview Sistem	3
2. Arsitektur Berlapis (Layered Architecture).....	3
3. Komponen Backend (FastAPI)	4
3.1 Router & Endpoint.....	4
3.2 Middleware Stack	5
4. Implementasi Keamanan (CIA + AAA).....	5
4.1 Authentication :Siapa Anda?	5
4.2 Authorization :Apa yang Boleh Dilakukan?	6
4.3 Accounting :Apa yang Sudah Dilakukan?.....	6
4.4 Enkripsi Data (Confidentiality)	6
4.5 Tanda Tangan Digital (Non-Repudiation).....	7
5. Arsitektur Deployment.....	7
6. Alur Data Request (Authenticated)	8

1. Overview Sistem

IPB Food Hub adalah platform pemesanan makanan kampus berbasis web yang menghubungkan mahasiswa IPB dengan pelaku UMKM kuliner kampus. Sistem dirancang dengan memperhatikan aspek keamanan informasi secara menyeluruh meliputi Authentication, Authorization, dan Accounting (AAA), enkripsi data sensitif, serta non-repudiation transaksi menggunakan tanda tangan digital.

Nama Sistem	IPB Food Hub & UMKM Management System
Domain	ipb-food-hub.vercel.app
Versi	1.0.0
Tipe Aplikasi	Full-stack Web Application (SPA + REST API)
Tech Stack	React 18 (Frontend) · FastAPI (Backend) · PostgreSQL (Database)
Infrastruktur	Vercel (Frontend + Backend Serverless) · Neon DB (PostgreSQL Cloud)
Standar Keamanan	JWT / OAuth2 · bcrypt · AES-256-GCM · RSA-2048 PSS · OWASP Top 10

2. Arsitektur Berlapis (Layered Architecture)

Sistem menggunakan arsitektur tiga lapis yang diimplementasikan sebagai berikut:

Layer	Komponen	Teknologi	Keamanan
Presentation Layer	React SPA + React Router + React Query	React 18, Tailwind CSS, Vite	Role-based route guard, JWT disimpan di memory (bukan localStorage)
Application Layer	FastAPI REST API + Middleware Stack	FastAPI, Python 3.12, Uvicorn	JWT validation, RBAC, AAA audit logging middleware, CORS whitelist
Data Layer	PostgreSQL (Neon DB)	PostgreSQL 16, SQLAlchemy ORM	Enkripsi kolom sensitif AES-256-GCM, indeks audit log

CDN / Storage	Cloudinary (foto menu, profil, bukti bayar)	Cloudinary API	Upload hanya dari backend, URL signed
---------------	---	----------------	---------------------------------------

3. Komponen Backend (FastAPI)

3.1 Router & Endpoint

Router	Prefix	Role yang Diizinkan	Fungsi Utama
auth	/api/auth	public / semua	Register, login (JWT issue), profil, update password
umkm	/api/umkm	pemilik_umkm, mahasiswa, admin	CRUD UMKM, daftar toko, detail toko
menu	/api/menu	pemilik_umkm, mahasiswa	CRUD menu, foto menu (Cloudinary)
pesanan	/api/pesanan	mahasiswa, pemilik_umkm, admin	Buat pesanan, update status, tanda tangan digital
pembayaran	/api/pesanan	mahasiswa, pemilik_umkm	Upload bukti bayar, konfirmasi pembayaran
rating	/api/rating	mahasiswa, pemilik_umkm	Beri rating & komentar, balas ulasan
promo	/api/promo	pemilik_umkm, mahasiswa	Buat & kelola promo diskon
admin	/api/admin	admin	Manajemen user, UMKM, dashboard statistik
security	/api/security	admin	Security dashboard: audit log, AAA events, anomaly detection

3.2 Middleware Stack

Middleware	Posisi	Fungsi
CORS Middleware	1 :paling luar	Whitelist origin (localhost:5173, ipb-food-hub.vercel.app), credentials=True
Audit Logging Middleware	2 :sebelum router	Catat setiap request ke tabel audit_logs: method, endpoint, status_code, IP, duration_ms
OAuth2 / JWT Validation	3 :per endpoint (Depends)	Dekode & validasi JWT Bearer token, inject current_user ke handler
Role Guard (require_role)	4 :per endpoint (Depends)	Cek role user vs. allowed_roles; tolak dengan 403 + catat ACCESS_DENIED

4. Implementasi Keamanan (CIA + AAA)

4.1 Authentication :Siapa Anda?

Mekanisme	Algoritma / Library	Detail Implementasi
Password Hashing	bcrypt (work factor 12)	get_password_hash() & verify_password() di core/security.py
Token Penerbitan	JWT HS256, python-jose	create_access_token() dengan payload {sub: user_id, role, exp}
Token Masa Berlaku	Configurable via env	ACCESS_TOKEN_EXPIRE_MINUTES di .env (default 60 menit)
Token Validasi	jwt.decode() + DB user check	get_current_user() validasi signature + cek user.status == 'aktif'

4.2 Authorization :Apa yang Boleh Dilakukan?

Role	Hak Akses Utama
mahasiswa	Browsing UMKM & menu, buat & lacak pesanan, upload bukti bayar, beri rating
pemilik_umkm	CRUD UMKM milik sendiri, kelola menu & promo, konfirmasi pembayaran, balas rating
admin	Manajemen seluruh user & UMKM, lihat security dashboard & audit log, suspend akun

4.3 Accounting :Apa yang Sudah Dilakukan?

Mekanisme	Event yang Dicatat	Penyimpanan
Audit Logging Middleware	Setiap HTTP request ke /api/* (method, endpoint, status, IP, user_id, duration)	Tabel audit_logs (PostgreSQL) :terindeks by created_at, user_id, endpoint
AAA JSON Log (file)	LOGIN_SUCCESS, LOGIN_FAILED, USER_REGISTER, ACCESS_GRANTED, ACCESS_DENIED, PROFILE_UPDATE	File 05_Testing/auth_activity.log (JSON Lines format)
Security Dashboard	Aggregasi real-time: total request, error rate, top endpoint, anomaly detection	Query dari tabel audit_logs via /api/security/dashboard

4.4 Enkripsi Data (Confidentiality)

Data Sensitif	Algoritma	Implementasi
no_telp, nomor_rekening, nomor_ewallet	NIK, AES-256-GCM	EncryptedString TypeDecorator di models/user.py; IV 12 byte random per nilai; IV Ciphertext GCM Tag disimpan sebagai base64 di DB

Password user	bcrypt (adaptive hash)	Tidak pernah disimpan plaintext; disimpan sebagai hash 60 karakter
RSA Private Key	RSA-2048 PEM	Disimpan di server (bukan DB), tidak di-commit ke git (.gitignore)

4.5 Tanda Tangan Digital (Non-Repudiation)

Aspek	Detail
Algoritma	RSA-2048 + PSS padding + SHA-256 (python cryptography library)
Trigger	Setiap transaksi pesanan yang selesai (status = selesai)
Payload yang Ditandatangani	JSON {pesanan_id, total_harga, timestamp} :sort_keys=True untuk determinisme
Penyimpanan Tanda Tangan	Base64-encoded signature disimpan di kolom tanda_tangan tabel pesanan
Verifikasi	verify_signature() di auth/digital_signature.py; dipanggil saat dispute transaksi
Key Management	Private key di server; Public key boleh dibagikan untuk verifikasi independen

5. Arsitektur Deployment

Komponen	Platform	URL / Konfigurasi
Frontend (React SPA)	Vercel (Static + CDN)	https://ipb-food-hub.vercel.app
Backend (FastAPI)	Vercel Serverless Functions	https://ipb-food-hub-api.vercel.app

Database	Neon DB (PostgreSQL serverless)	DATABASE_URL di Vercel env var (tidak ter-expose ke client)
Media Storage	Cloudinary CDN	CLOUDINARY_URL di Vercel env var
Environment Variables	Vercel Dashboard	SECRET_KEY, ENCRYPTION_KEY, RSA key paths, ALLOWED_ORIGINS

Catatan: ENCRYPTION_KEY (AES-256) dan SECRET_KEY (JWT) disimpan sebagai Vercel Environment Variables :tidak pernah ter-commit ke repository git.

6. Alur Data Request (Authenticated)

Step	Aktor	Aksi
1	Client (Browser)	User mengirim HTTP request dengan header Authorization: Bearer <JWT>
2	CORS Middleware	Validasi origin terhadap whitelist; tolak jika tidak cocok
3	Audit Logging Middleware	Start timer; extract user_id dari JWT (best-effort)
4	FastAPI Router	Route request ke handler yang sesuai
5	get_current_user()	Dekode JWT, query DB user, cek status='aktif'; log ACCESS_GRANTED
6	require_role()	Validasi role; jika gagal: log ACCESS_DENIED, raise 403
7	Handler Logic	Eksekusi business logic, akses DB via SQLAlchemy ORM
8	DB (Neon PostgreSQL)	Query/write data; kolom sensitif auto-decrypt oleh EncryptedString
9	Response	JSON response dikirim ke client
10	Audit Logging Middleware	Catat log ke audit_logs (async, setelah response dikirim)
